PROJECT 11 | SOC ANALYST PORTFOLIO

Suspicious Authentication Investigation: Microsoft Sentinel

How I investigated a password-guessing alert that turned into a confirmed account compromise, using KQL, threat intelligence and MITRE ATT&CK.;

Prepared by: Riyaz Shaik, SOC Analyst L1 | Report date: 04 October 2026 | SIEM: Microsoft Sentinel

1. Summary in Plain English

Imagine a security guard watching every door-badge swipe in a building. One night the same badge is swiped wrong many times, then suddenly works, then is used at a door it has never used before. The guard does not shrug because the badge eventually worked; they check the badge's history, check the timing, and decide whether to lock the door. This project is that same idea for a company login. I used Microsoft Sentinel (Microsoft's cloud SIEM) to watch sign-in logs, wrote detection rules for this exact pattern, investigated an alert from start to finish, enriched the evidence with outside threat intelligence, and wrote the full set of documents a SOC team produces.

Result at a glance
What happened: 10 failed sign-ins on account j.rao, then a success, then a second sign-in from another country 11 minutes later.
What fired: Two Sentinel rules - "success after failures" and "impossible travel".
My conclusion: Confirmed account compromise, not a false positive.
Severity: High, escalated to Tier-2 and contained in about 35 minutes.

2. Words You Need (Simple Glossary)

Term	Simple meaning
Microsoft Sentinel	Microsoft's cloud SIEM. Collects logs and raises alerts on suspicious patterns.
KQL	The search language used to ask Sentinel questions, e.g. "show every failed login this hour."
IOC	Indicator of Compromise: a clue that an attack happened, e.g. a bad IP.
Threat intelligence	Outside services that already track known-bad IP addresses and activity.
Impossible travel	The same account logging in from two places too far apart to reach in the time between logins.
Correlation rule	A rule that links several events together (failures + a later success + an odd location) instead of judging any one alone.

3. The Environment I Used

A private Microsoft Sentinel lab tenant with a Log Analytics workspace receiving Windows Security logs from a simulated corp.local domain (a Windows Server 2022 domain controller and a Windows 10 employee endpoint). No real company, employee or third party is involved.

Tool	Used for
Microsoft Sentinel	Incidents, analytics rules, entity investigation graph
KQL (Logs blade)	Querying the Security Event logs
Microsoft Defender	Sign-in risk and device state checks
VirusTotal, AbuseIPDB, AlienVault OTX	Threat intelligence enrichment of the two source IPs

4. The Story: What Happened

Time	Event
07:55	j.rao normally signs in from Hyderabad on a known laptop, business hours
08:00	10 failed sign-ins (Event 4625, Logon Type 3) from IP 103.21.XX.XX
08:05	11th attempt succeeds - Event 4624, same account, same IP
08:07	Sentinel rule fires: Successful Sign-In Following Multiple Failures
08:09	Second sign-in from Amsterdam, 11 minutes later - Impossible Travel alert fires
08:10	SOC Analyst (me) picks up the incident

5. What I Checked and What I Found

Event ID	Meaning	Why it mattered here
4625	Failed logon	Showed the 10-attempt guessing burst and its pattern
4624	Successful logon	Confirmed the attacker got in, and from where, twice
4648	Logon using explicit credentials	Checked for lateral movement - none found
4672	Special privileges assigned	Checked whether the account holds admin rights - clean, no escalation
4740	Account lockout	Checked whether the burst tripped a lockout - it did not

The core KQL query: failures followed by a success

```
let failures = SecurityEvent | where EventID == 4625 | summarize FailCount=count(),
FirstFail=min(TimeGenerated) by Account, IpAddress, bin(TimeGenerated,10m);
let successes = SecurityEvent | where EventID == 4624 and LogonType == 3 | project SuccessTime=TimeGenerated,
Account, IpAddress;
failures | where FailCount >= 5 | join kind=inner (successes) on Account, IpAddress
| where SuccessTime between (FirstFail .. FirstFail + 15m)
```

This is the single most important query in the investigation: it is the moment "someone was guessing" becomes "someone got in." I wrote 7 KQL queries in total, covering failed-login analysis, successful-login analysis, top source IPs, authentication trends, full account history, and an impossible-travel pattern query.

6. IOC Analysis and Threat Intelligence

Indicator	Value	Risk indicator
Source IP (burst 1)	103.21.XX.XX	Known hosting/VPN exit range
Source IP (burst 2)	185.244.XX.XX (Amsterdam)	No prior history for this user
Username	j.rao (Finance)	Standard rights, no privilege escalation
Event pattern	10 failures in <2 min, success 5 min later, 2nd-country sign-in 11 min after that	Matches brute force then compromise then session reuse

Source	Finding	Risk level
VirusTotal	103.21.XX.XX flagged by 9 of 94 vendors for credential-stuffing activity	Medium-High
AbuseIPDB	103.21.XX.XX: 78% abuse confidence, reported for brute force in last 30 days. 185.244.XX.XX: 61% abuse confidence.	High
AlienVault OTX	103.21.XX.XX appears in a public pulse tagged credential access / T1110	High

7. What I Checked, What I Concluded, and Why

Before escalating, I ruled out every innocent explanation rather than assuming the worst:

Question I asked	What I checked	Conclusion
Could this be the user travelling?	Called the user directly	No - confirmed still in Hyderabad at the time

Question I asked	What I checked	Conclusion
Could this be a shared VPN exit IP the user legitimately uses?	Checked against known corporate VPN ranges	No - user does not use a VPN that exits via Amsterdam
Could this be a mistyped password burst?	Checked sub-status codes on the 10 failures	No - pattern matches guessing, not one person retrying
Could the threat intel be wrong or outdated?	Compared two independent sources plus the travel math	No - AbuseIPDB and OTX agree, and impossible travel does not depend on reputation data at all

> **Conclusion**
> All four checks point the same direction: this is a true positive, confirmed account compromise - not a false alarm.

8. The 5 Detection Rules I Built

Rule	Fires when	MITRE	Severity
1. Multiple failed logins	5+ failures, one account/IP, 10-minute window	T1110 Brute Force	Medium
2. Success after failures	A success lands within 15 min of a failure burst, same account/IP	T1078 Valid Accounts	High
3. Unusual location	Valid account signs in from outside its known IP range	T1078 Valid Accounts	Medium-High
4. Impossible travel	Two different source IPs for the same account, under 60 minutes apart	T1078 Valid Accounts	Critical
5. Multiple accounts, same IP	One IP fails against 5+ different accounts	T1110.003 Password Spraying	High

Checked against Rule 5: only **one** account was targeted in this incident, so it was classified as a targeted brute force, not a password spray.

9. Alert Triage

Field	Value
Alert Name	Successful Sign-In Following Multiple Failures - Possible Account Compromise
Alert Severity	High
Alert Confidence	High - corroborated by the Impossible Travel alert firing independently
Triage Decision	Escalate - confirmed compromise, not a false positive

10. Response: What I Did

Action	Why it was required
Disabled the j.rao account	Removes the attacker's access immediately
Revoked all active sessions and tokens	A password reset alone does not end an already-active session
Blocked both source IPs	Stops the same source from retrying right away
Forced password reset and MFA re-enrolment	Removes the credential the attacker proved they knew, and closes the gap that let them in
Reviewed mailbox for forwarding rules	Checked for a hidden way the attacker could keep reading mail - none found
Escalated to Tier-2	Exceeds L1 authority to close independently; needed forensic mailbox review

Incident ticket INC-2026-0511 (P1, High) recorded the summary, root cause, impact, actions taken and recommendations, and was escalated with a clear note: request mailbox forensic review for data access during the roughly 35-minute compromise window.

11. MITRE ATT&CK Mapping

Technique	ID	Tactic	How it applied here
Brute Force	T1110	Credential Access	The 10-failure burst against j.rao
Password Spraying	T1110.003	Credential Access	Checked and ruled out - only one account targeted
Valid Accounts	T1078	Initial Access / Persistence	The successful sign-in using the guessed password
Cloud Accounts	T1078.004	Initial Access / Persistence	The hybrid identity's session reused in the second sign-in
Account Discovery	T1087	Discovery	Checked for - no evidence other accounts were enumerated

12. What I Found in This Project (Key Findings)

- **Correlation beats single alerts.** The failure burst alone would likely have been triaged as low priority. It was linking two rules - success-after-failure and impossible-travel - that turned it into a confident, fast escalation.
- **No MFA was the single enabling factor.** The attacker still needed 11 tries, so the password was not trivially weak, but nothing stopped them from using it once guessed.
- **Verifying with the user mattered.** A phone call ruled out the most likely innocent explanation (travel) in under a minute.
- **No privilege escalation occurred,** which is what kept this at High rather than Critical severity.

13. What I Would Improve

- **Confirm the mailbox review outcome.** At the time of this report the Tier-2 forensic review was still pending; the final severity should be revisited once it completes.

- **Automate the user-verification step.** Calling the user worked here, but a documented, repeatable contact process (not an ad hoc call) would scale better.
- **Test Rule 3 for noise.** "Unusual location" depends on an accurate, maintained list of each user's known IP range, and needs tuning against real travel and remote-work patterns.
- **Move impossible travel from alert-only to blocking** in Conditional Access, so the second sign-in could not have completed at all.
- **Add a standing alert for mailbox auto-forwarding rules,** rather than checking manually during each incident.

14. What I Actually Learned

- How to write KQL that correlates two separate event types (failures and a success) instead of alerting on either alone.
- How to use outside threat intelligence (VirusTotal, AbuseIPDB, OTX) to turn "this looks odd" into "two independent sources confirm this is bad."
- How to build a false-positive checklist and work through it before escalating, rather than after.
- How a SOC severity decision depends on specific evidence (privilege escalation, confirmed access) and not just how alarming an alert sounds.

15. How This Connects to the Real World

Password-guessing followed by account takeover is one of the most common ways real attackers get into company email and cloud accounts, especially where MFA is not yet enforced everywhere. Impossible-travel detection is a standard control in real Microsoft Entra ID and Sentinel deployments for exactly this reason. The investigation steps here - check the event IDs, correlate failures with success, enrich with threat intelligence, verify with the user, then escalate - match how a real Tier-1 SOC analyst works a case before handing it to Incident Response.

16. Final Recommendations

Priority	Recommendation	Why
1	Enforce MFA tenant-wide	Would have stopped the second, actual-use sign-in even after the password was guessed. The single biggest fix.
2	Turn on Conditional Access impossible-travel blocking, not just alerting	Prevents the second sign-in from completing at all.
3	Apply a fine-grained password policy to block common or weak passwords	Reduces how often an 11-try guess succeeds.
4	Deploy all 5 rules as live, scheduled Sentinel analytics rules	A rule that is not running protects nobody.
5	Add a standing alert for mailbox auto-forwarding rules	Catches a hidden way to keep reading mail after containment.

17. Conclusion

A Finance account was compromised through password guessing and detected through the correlation of two independent Sentinel rules within two minutes of the compromising sign-in. The account was contained in roughly 35 minutes, before privilege escalation or confirmed data loss occurred. The clearest lesson is that correlating related signals, rather than judging any single alert alone, is what turned a routine-looking failure burst into a fast, confident, defensible escalation. With MFA and impossible-travel blocking in place, this exact path into the account would have been closed.

Honest limits of this report

This incident, account, and IP addresses are simulated for a portfolio lab exercise. Mailbox forensic review was still pending with Tier-2 at the time of writing, so the final confirmed impact (whether any data was actually accessed) is not yet closed out.